# Endpoint Protection

View Only



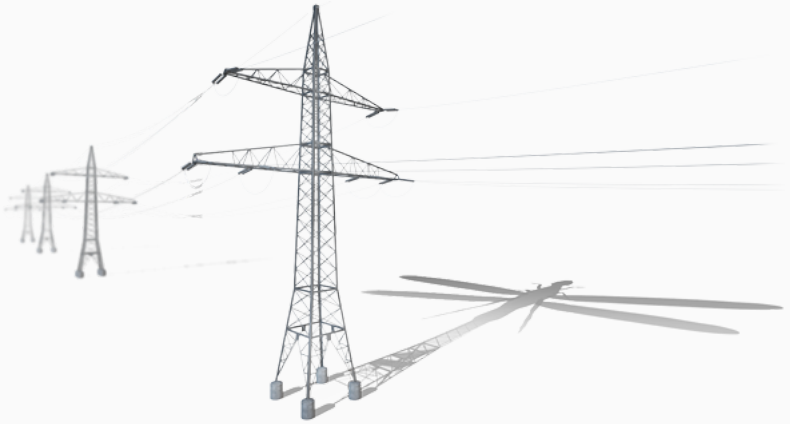
## Dragonfly: Western Energy Companies Under Sabotage Threat

Recommend

Jun 30, 2014 08:58 AM

A L Johnson

Statistics
0 Favorited
11 Views
0 Files
0 Shares
0 Downloads



An ongoing cyberespionage campaign against a range of targets, mainly in the energy sector, gave attackers the ability to mount sabotage operations against their victims. The attackers, known to Symantec as Dragonfly, managed to compromise a number of strategically important organizations for spying purposes and, if they had used the sabotage capabilities open to them, could have caused damage or disruption to energy supplies in affected countries.

Among the targets of Dragonfly were energy grid operators, major electricity generation firms, petroleum pipeline operators, and energy industry industrial equipment providers. The majority of the victims were located in the United States, Spain, France, Italy, Germany, Turkey, and Poland.

The Dragonfly group is well resourced, with a range of malware tools at its disposal and is capable of launching attacks through a number of different vectors. Its most ambitious attack campaign saw it compromise a number of industrial control system (ICS) equipment providers, infecting their software with a remote access-type Trojan. This caused companies to install the malware when downloading software updates for computers running ICS equipment. These infections not only gave the attackers a beachhead in the targeted organizations' networks, but also gave them the means to mount sabotage operations against infected ICS computers.

This campaign follows in the footsteps of Stuxnet, which was the first known major malware campaign to target ICS systems. While Stuxnet was narrowly targeted at the Iranian nuclear program and had sabotage as its primary goal, Dragonfly appears to have a much broader focus with espionage and persistent access as its current objective with sabotage as an optional capability if required.

In addition to compromising ICS software, Dragonfly has used spam email campaigns and watering hole attacks to infect targeted organizations. The group has used two main malware tools: Backdoor.Oldrea and Trojan.Karagany. The former appears to be a custom piece of malware, either written by or for the attackers.

Prior to publication, Symantec notified affected victims and relevant national authorities, such as Computer Emergency Response Centers (CERTs) that handle and respond to Internet security incidents.

**Background**

The Dragonfly group, which is also known by other vendors as Energetic Bear, appears to have been in operation since at least 2011 and may have been active even longer than that. Dragonfly initially targeted defense and aviation companies in the US and Canada before shifting its focus mainly to US and European energy firms in early 2013.

The campaign against the European and American energy sector quickly expanded in scope. The group initially began sending malware in phishing emails to personnel in target firms. Later, the group added watering hole attacks to its offensive, compromising websites likely to be visited by those working in energy in order to redirect them to websites hosting an exploit kit. The exploit kit in turn delivered malware to the victim's computer. The third phase of the campaign was the Trojanizing of legitimate software bundles belonging to three different ICS equipment manufacturers.

Dragonfly bears the hallmarks of a state-sponsored operation, displaying a high degree of technical capability. The group is able to mount attacks through multiple vectors and compromise numerous third party websites in the process. Dragonfly has targeted multiple organizations in the energy sector over a long period of time. Its current main motive appears to be cyberespionage, with potential for sabotage a definite secondary capability.

Analysis of the compilation timestamps on the malware used by the attackers indicate that the group mostly worked between Monday and Friday, with activity mainly concentrated in a nine-hour period that corresponded to a 9am to 6pm working day in the UTC +4 time zone. Based on this information, it is likely the attackers are based in Eastern Europe.

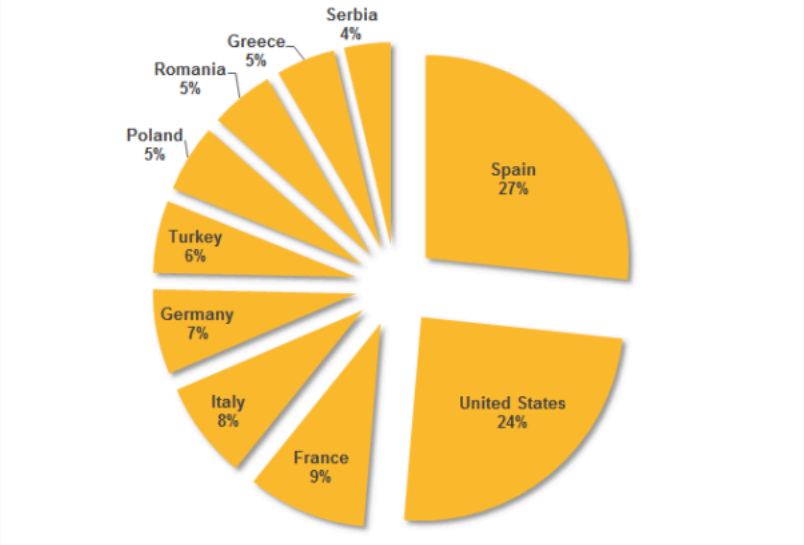



***Figure.*** *Top 10 countries by active infections (where attackers stole information from infected computers)*

**Tools employed**

Dragonfly uses two main pieces of malware in its attacks. Both are remote access tool (RAT) type malware which provide the attackers with access and control of compromised computers. Dragonfly's favored malware tool is Backdoor.Oldrea, which is also known as Havex or the Energetic Bear RAT. Oldrea acts as a back door for the attackers on to the victim's computer, allowing them to extract data and install further malware.

Oldrea appears to be custom malware, either written by the group itself or created for it. This provides some indication of the capabilities and resources behind the Dragonfly group.

Once installed on a victim's computer, Oldrea gathers system information, along with lists of files, programs installed, and root of available drives. It will also extract data from the computer's Outlook address book and VPN configuration files. This data is then written to a temporary file in an encrypted format before being sent to a remote command-and-control (C&C) server controlled by the attackers.

The majority of C&C servers appear to be hosted on compromised servers running content management systems, indicating that the attackers may have used the same exploit to gain control of each server. Oldrea has a basic control panel which allows an authenticated user to download a compressed version of the stolen data for each particular victim.

The second main tool used by Dragonfly is Trojan.Karagany. Unlike Oldrea, Karagany was available on the underground market. The source code for version 1 of Karagany was leaked in 2010. Symantec believes that Dragonfly may have taken this source code and modified it for its own use. This version is detected by Symantec as Trojan.Karagany!gen1.

Karagany is capable of uploading stolen data, downloading new files, and running executable files on an infected computer. It is also capable of running additional plugins, such as tools for collecting passwords, taking screenshots, and cataloging documents on infected computers.

Symantec found that the majority of computers compromised by the attackers were infected with Oldrea. Karagany was only used in around 5 percent of infections. The two pieces of malware are similar in functionality and what prompts the attackers to choose one tool over another remains unknown.

**Multiple attack vectors**

The Dragonfly group has used at least three infection tactics against targets in the energy sector. The earliest method was an email campaign, which saw selected executives and senior

employees in target companies receive emails containing a malicious PDF attachment. Infected emails had one of two subject lines: “The account” or “Settlement of delivery problem”. All of the emails were from a single Gmail address.

The spam campaign began in February 2013 and continued into June 2013. Symantec identified seven different organizations targeted in this campaign. The number of emails sent to each organization ranged from one to 84.

The attackers then shifted their focus to watering hole attacks, comprising a number of energy-related websites and injecting an iframe into each which redirected visitors to another compromised legitimate website hosting the Lightsout exploit kit. Lightsout exploits either Java or Internet Explorer in order to drop Oldrea or Karagany on the victim’s computer. The fact that the attackers compromised multiple legitimate websites for each stage of the operation is further evidence that the group has strong technical capabilities.

In September 2013, Dragonfly began using a new version of this exploit kit, known as the Hello exploit kit. The landing page for this kit contains JavaScript which fingerprints the system, identifying installed browser plugins. The victim is then redirected to a URL which in turn determines the best exploit to use based on the information collected.

**Trojanized software**
The most ambitious attack vector used by Dragonfly was the compromise of a number of legitimate software packages. Three different ICS equipment providers were targeted and malware was inserted into the software bundles they had made available for download on their websites. All three companies made equipment that is used in a number of industrial sectors, including energy.

The first identified Trojanized software was a product used to provide VPN access to programmable logic controller (PLC) type devices. The vendor discovered the attack shortly after it was mounted, but there had already been 250 unique downloads of the compromised software.

The second company to be compromised was a European manufacturer of specialist PLC type devices. In this instance, a software package containing a driver for one of its devices was compromised. Symantec estimates that the Trojanized software was available for download for at least six weeks in June and July 2013.

The third firm attacked was a European company which develops systems to manage wind turbines, biogas plants, and other energy infrastructure. Symantec believes that compromised software may have been available for download for approximately ten days in April 2014.

The Dragonfly group is technically adept and able to think strategically. Given the size of some of its targets, the group found a “soft underbelly” by compromising their suppliers, which are invariably smaller, less protected companies.

**Protection**
Symantec has the following detections in place that will protect customers running up to date versions of our products from the malware used in these attacks:

**Antivirus detections**

- Backdoor.Oldrea
- Trojan.Karagany
- Trojan.Karagany!gen1

**Intrusion Prevention Signatures**

- Web Attack: Lightsout Exploit Kit
- Web Attack: Lightsout Toolkit Website 4

For further technical details on the Dragonfly attacks, please read our whitepaper.

## Tags and Keywords

## Related Entries and Links

No Related Resource entered.

Copyright © 2005-2026 Broadcom. All Rights Reserved. The term "Broadcom" refers to Broadcom Inc. and/or its subsidiaries.
Hosted by Higher Logic, LLC on the behalf of Broadcom - Privacy Policy | Cookie Policy | Supply Chain Transparency

Terms of Use